Eskalacja Uprawnień Poza Rolę:

Demonstracja Broken Access Control

Jak błędy w autoryzacji pozwalają na przejęcie kontroli nad aplikacją.

JACOB CZAJKA | JAKUB BOGUNIA



Uwierzytelnienie a Autoryzacja

Uwierzytelnienie

Kim jesteś?

Potwierdza tożsamość
np. logowanie loginem
i hasłem

Autoryzacja

Co możesz zrobić?

Określa uprawnienia
np. prawo do usunięcia
pliku

**Aplikacje często dobrze sprawdzają tożsamość,
ale rzadko prawidłowo egzekwują uprawnienia.**



Czym jest Broken Access Control (BAC)?

Błąd w egzekwowaniu ograniczeń dostępu dla uwierzytelnionych użytkowników

Od lat na liście OWASP Top 10 – jedna z najgroźniejszych luk

Umożliwia dostęp do kont innych użytkowników, podgląd lub modyfikację wrażliwych danych, zmianę praw i niszczenie danych



Rodzaje eskalacji uprawnień (BAC)

Eskalacja Horyzontalna

Dostęp do zasobów innego użytkownika
o tym samym poziomie uprawnień

Przykład: Alicja czyta prywatne wiadomości Boba

Eskalacja Wertykalna

Zwykły użytkownik uzyskuje prawa administratora

Przykład: dostęp do “/admin_panel” i usunięcie kont



Jak zapobiegać Broken Access Control?

Domyślna odmowa dostępu
blokuj dostęp do zasobów niepublicznych

Sprawdzanie uprawnień po stronie serwera
nie ufaj danym z przeglądarki

Weryfikacja właściciela zasobu
zawsze sprawdzaj, czy użytkownik jest właścicielem rekordu w bazie
np. SELECT * FROM docs WHERE id=? AND owner_id=?



Bibliografia i Źródła

OWASP Top 10: A01:2021 –
Broken Access Control (owasp.org)

PortSwigger Web Security Academy:
Access Control Vulnerabilities (portswigger.net)

The Web Application Hacker's Handbook
(D. Stuttard, M. Pinto) – Rozdział 8:
Attacking Access Controls

